EUREKA HACKATHON / OT CYBERSECURITY

OTProof

Evidence-first vulnerability applicability and remediation assurance for industrial assets

- Reconcile an operator inventory with public ICS advisories
- Show exact product/version evidence and uncertainty
- Keep engineering and approval decisions human-owned

OTPROOF / FIELD VIEW

READ-ONLY

No OT interaction in this MVP

- 80 fictional assets
- 3 real CISA advisories
- Offline-ready demo

The review gap lives between two records

An advisory lists products and versions. An operator owns assets, maintenance context, and change decisions.

01 **Inventory identifiers and advisory product language often differ**

02 A version match can be exact, excluded, or impossible to confirm

03 Teams must preserve the source and explain what they decided

OTPROOF / FIELD VIEW

3 RECORDS

Inventory · advisory · remediation evidence

- Asset inventory
- Public advisory
- Engineering record

Critical infrastructure needs cautious handling

Water, energy, oil and gas, and industrial operators balance security with continuity, safety, and maintenance constraints.

01 **A vulnerability label alone does not prove local applicability**

02 A patch suggestion is not an approved operational change

03 Human review and source traceability belong in the workflow

OTPROOF / FIELD VIEW

NO DEVICE

Discovery or configuration change

- File-based inventory
- Public source egress
- Human-led review

NIST SP 800-82 Rev. 3 final; Rev. 4 remains an initial public draft as of 26 Oct 2026.

One auditable workflow from import to assurance

A repeatable sequence connects a source statement to an engineering decision and evidence record.

01 **Validate inventory and import approved public advisory data**

02 Compare vendor, product, configuration, and version constraints

03 Record review, ticket approval, evidence, and verification



End-to-end journey is implemented in the MVP dashboard and API.

Demo: three assets, three distinct outcomes

A CISA FactoryTalk View advisory exposes why version and inventory quality matter.

01 **FactoryTalk View SE 13.0.0 → applicable candidate**

02 FactoryTalk View SE 14.0 → outside the exact affected version

03 Same product with missing firmware → engineering review

OTPROOF / FIELD VIEW

ICSA-24-226-06

CISA · published 13 Aug 2024 · updated 29 Aug 2024

- CVE-2024-7513
- Source statement: version 13.0
- Source URL retained

https://www.cisa.gov/news-events/ics-advisories/icsa-24-226-06

Deterministic matching earns each conclusion

A small ruleset handles explicit source evidence; unsupported cases abstain.

01 **Normalize only curated vendor and product aliases**

02 Apply explicit equality and inclusive/exclusive version bounds

03 Route ambiguity, stale data, duplicates, and unknown syntax to review

OTPROOF / FIELD VIEW

3 OUTCOMES

Applicable · not applicable · manual verification

- Exact identity
- Published constraint
- Traceable rationale

Matcher implementation: backend/app/services/matching.py

AI reads advisory text; people decide

The local model is an optional extraction assistant behind schema and source checks.

01 **Draft structured vendor, product, CVE, version, and mitigation fields**

02 Treat embedded advisory instructions as untrusted text

03 Keep model output out of applicability and remediation state

OTPROOF / FIELD VIEW

OPTIONAL

Local Ollama adapter · no inference run in evaluation

- Pydantic schema
- Verbatim source evidence
- Suggestion only

Optional Qwen2.5 7B Instruct model; Apache-2.0 model repo. No weights included.

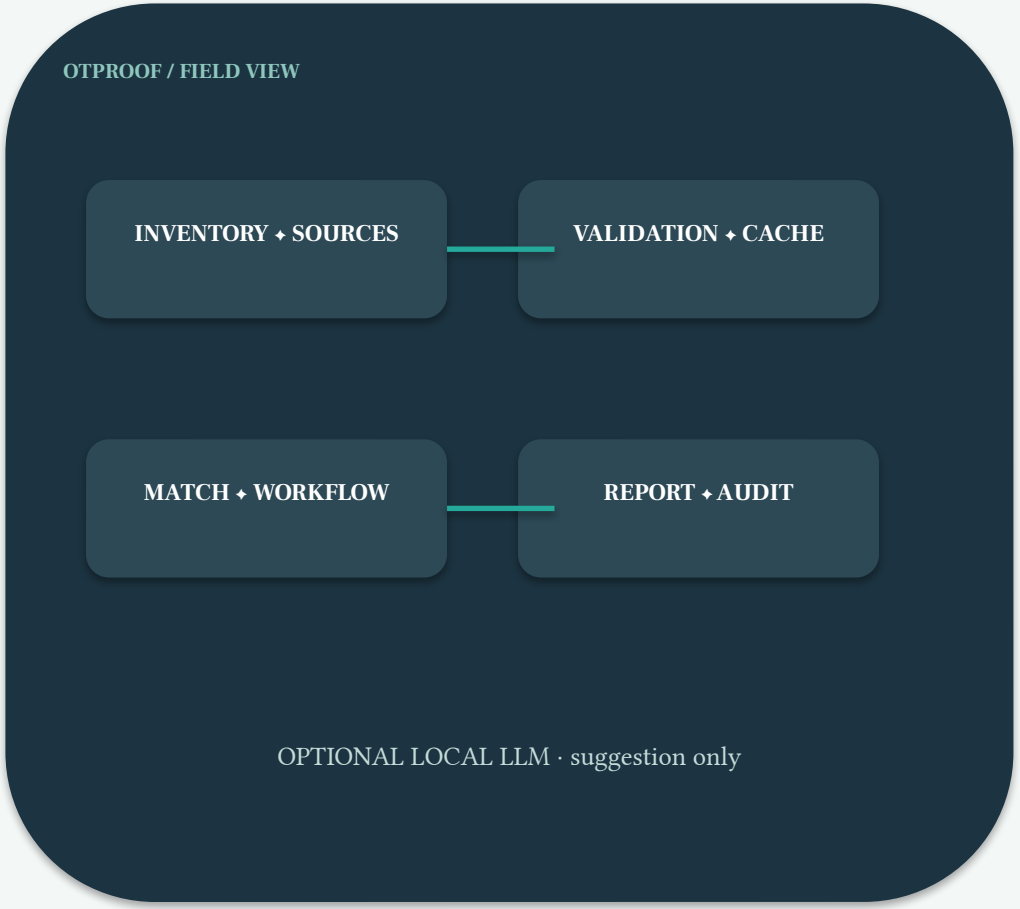
A compact architecture keeps evidence close to the decision

A modular monolith is easier to inspect and package for a controlled first pilot.

01 **React ✦ TypeScript dashboard, FastAPI ✦ Pydantic service**

02 PostgreSQL deployment; SQLite for local offline demonstration

03 Cached public sources, deterministic matcher, audit and report services



Full technical design: OTProof_Technical_Design.md

From finding to verified evidence

Role separation prevents generated text or a proposed ticket from becoming a remediation claim.

01 **Reviewer records applicability with a rationale**

02 Engineer proposes action; approver accepts or rejects

03 Approver verifies evidence before the workflow closes

OTPROOF / FIELD VIEW

4 ROLES

Engineer · reviewer · approver · admin

- Decision
- Ticket
- Evidence
- Verification

Demo bearer tokens are public; production identity integration is required.

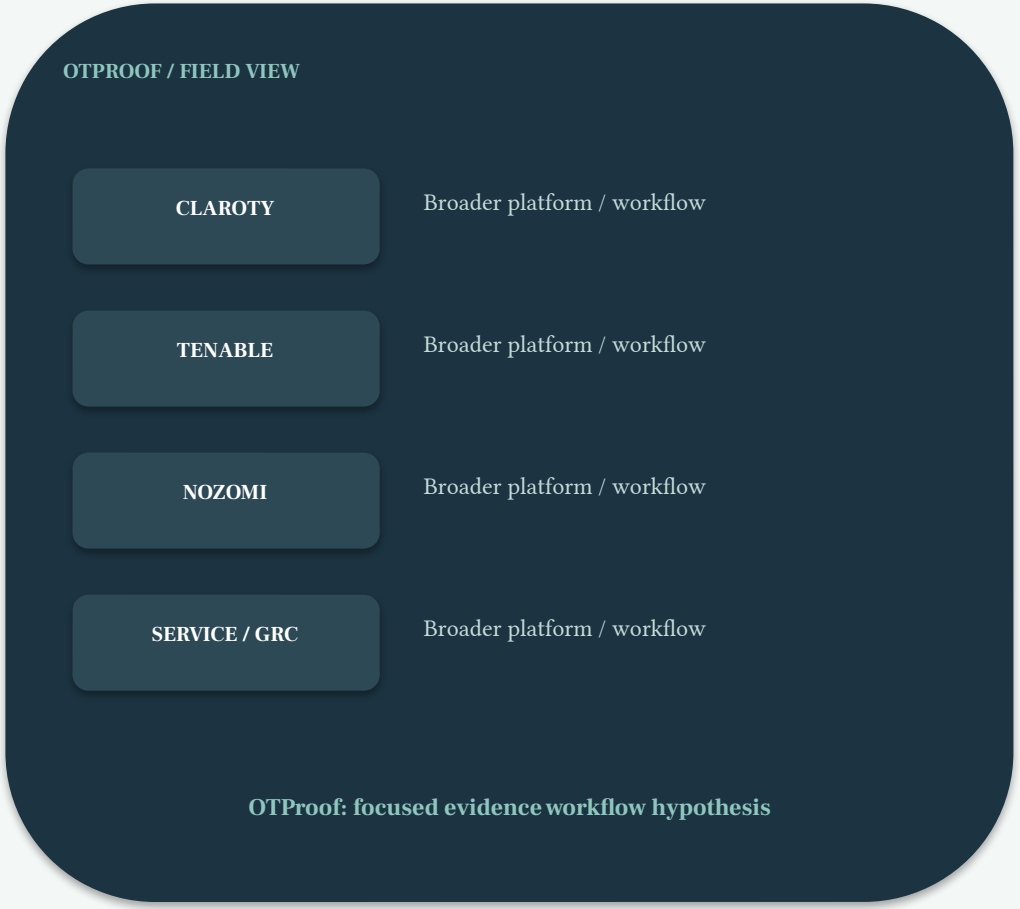
Positioning: complement an established OT security landscape

Broad platforms already offer inventory and exposure workflows; the proposed wedge is narrower.

01 **Claroty, Tenable, and Nozomi describe broad OT visibility and risk products**

02 GRC / IRM platforms manage enterprise risk, controls, and audit workflow

03 Test if source-linked review fills a process gap or integrates cleanly



Claroty · Tenable · Nozomi · ServiceNow public product documentation; see notes.

A site license plus deployment and assurance services

Start with a transparent per-site hypothesis, then validate effort and willingness to pay.

01 **Illustrative license: $36,000 per site per year**

02 Illustrative onboarding: $25,000 per new customer

03 Enterprise tiers, integrations, and ongoing review services are options

OTPROOF / FIELD VIEW

1 customer	$108k ARR
5 customers	$540k ARR
10 customers	$1.08m ARR
25 customers	$2.70m ARR

Illustrative arithmetic only; assumptions in OTProof_Business_Case.pdf.

MVP baseline: correct on a small, explicit fixture set

The results show the code follows the labels supplied; they do not estimate field accuracy.

01 **14/14 labeled cases matched expected outcomes**

02 4 applicable cases: 100% fixture precision/recall, 0 fixture false negatives

03 6/6 uncertainty cases abstained; 14/14 outputs had source traceability



reports/evaluation_metrics.json · run dated 26 Oct 2026

Trust boundaries are product requirements

Keep OT interactions passive and offline in the MVP, and reserve consequential decisions for people.

01 **No scan, exploit, device query, or configuration modification**

02 Treat uploads and advisory text as untrusted content

03 Approval and verification require role-gated human action

OTPROOF / FIELD VIEW

HUMAN

Owns applicability and remediation decisions

- Public sources only
- Evidence and audit trail
- Production auth still required

Threat model, identity, immutable audit, and security testing remain pilot work.

Next: validate with OT engineers and real workflow constraints

The next milestone is evidence of usefulness, not a larger feature checklist.

01 **Recruit 3–5 operator or managed-service design partners**

02 Build a blinded, multi-vendor adjudication set with engineers

03 Measure false negatives, abstentions, review time, and onboarding effort

OTPROOF / FIELD VIEW

PILOT ASK

Water / energy operator + OT engineering reviewers

- Broaden source/vendor coverage
- Add SSO and durable audit
- Test CMMS / GRC connectors

No customer interviews, paid pilots, or measured savings are claimed yet.